

Discussion 2: Initial Post

Abinel Madzivire

The Common Vulnerability Scoring System (CVSS) is widely used to provide a standardised numerical representation of vulnerability severity. However, Wunder *et al.* (2024) identify significant concerns regarding its consistency and reliability. Their central criticism is that CVSS depends considerably on human interpretation when assigning values to individual metrics. In their study of 196 CVSS users, the authors found particularly inconsistent assessments of Attack Vector, User Interaction and Scope for common vulnerabilities. Furthermore, in a follow-up study conducted nine months later, 68% of participants changed the severity rating they had previously assigned to the same vulnerabilities (Wunder *et al.*, 2024).

Another concern is ambiguity within the CVSS metrics and supporting guidance. Although CVSS is intended to produce comparable assessments regardless of evaluator, Wunder *et al.* (2024) found that differences were more closely associated with characteristics of CVSS itself than with evaluators' professional experience. Significantly, 85% of participants considered CVSS inconsistent, although 80% still regarded it as useful. This suggests that CVSS retains practical value as a common language for communicating vulnerability severity, but its numerical precision should not automatically be interpreted as objective risk.

I agree substantially with this critique. Vulnerability management requires organisations to prioritise limited remediation resources, meaning inconsistent scores can result in resources being directed towards less important vulnerabilities while genuinely dangerous vulnerabilities remain exposed. Furthermore, CVSS measures severity rather than organisational risk; FIRST itself distinguishes these concepts and

cautions against using CVSS as the sole basis for vulnerability prioritisation (Wunder *et al.*, 2024). Earlier research similarly questions the suitability of CVSS scores for risk-based vulnerability prioritisation (Spring *et al.*, 2021).

One compelling alternative is the Exploit Prediction Scoring System (EPSS). Rather than primarily estimating the technical severity of a vulnerability, EPSS uses empirical data to estimate the probability that a published vulnerability will be exploited in the wild. This provides a more operationally meaningful basis for deciding which vulnerabilities require urgent remediation. Research indicates that high CVSS severity does not necessarily correspond with real-world exploitation, whereas exploitation-focused approaches can improve vulnerability prioritisation (Jacobs *et al.*, 2021).

I would therefore argue that EPSS offers a stronger basis for operational prioritisation than CVSS because it addresses the question security teams most urgently need answered: how likely is this vulnerability to be exploited? Nevertheless, completely replacing CVSS would discard useful information about potential technical impact. A stronger practical approach may therefore be to make exploitation probability the primary prioritisation mechanism while retaining CVSS severity as complementary information. This would combine the likelihood of exploitation with the consequences of successful exploitation and provide a more defensible basis for risk-informed vulnerability management.

References

Jacobs, J., Romanosky, S., Edwards, B., Adjerid, I. and Roytman, M. (2021) 'Exploit prediction scoring system (EPSS)', *Digital Threats: Research and Practice*, 2(3), pp. 1–17. doi: 10.1145/3436242.

Spring, J.M., Hatleback, E., Householder, A.D., Manion, A. and Shick, D. (2021) 'Time to change the CVSS?', *IEEE Security & Privacy*, 19(2), pp. 74–78. doi: 10.1109/MSEC.2020.3044475.

Wunder, J., Kurtz, A., Eichenmüller, C., Gassmann, F. and Benenson, Z. (2024) 'Shedding light on CVSS scoring inconsistencies: A user-centric study on evaluating widespread security vulnerabilities', *2024 IEEE Symposium on Security and Privacy (SP)*, pp. 1102–1121. doi: 10.1109/SP54263.2024.00058.